ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric EcoStruxure Panel Server PAS600 · Component type: **Embedded Device (EDR) + Network Device (NDR) - gateway** · Target SL = SL 3

Where to work	Embedded **webpages (HTTPS)** and **EcoStruxure Power Commission (EPC)** software for configuration; wireless-sensor **pairing** (Zigbee/Thread); Modbus TCP server/gateway; Maintenance › Device Information for firmware.
Interfaces / ports	HTTPS **443** (webUI); **Modbus TCP 502** (server + gateway); **SNMP 161**; **MQTT 8883** (TLS); NTP **123**; Syslog; SFTP; wireless sensor mesh (802.15.4 Zigbee/Thread).
Firmware note	Confirm firmware **>= 002.006.000** and model (PAS600 / PAS600L) in Maintenance › Device Information. Follow **DOCA0211 EcoStruxure Panel Server Cybersecurity Guide** as the hardening baseline. Ships self-signed cert -> replace with CA-signed.
How to read	Default read-only (read-only webUI/EPC account). Native how-to + external-tool validation + pass. Write/exploit tools = **isolated + written authorization**. Component is both **EDR** (the gateway device) and **NDR** (its Modbus gateway / wireless-mesh function).

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the PanelServer configuration backup/export via the **web server** or **EcoStruxure Power Commission (EPC)**, the paired wireless-sensor list (Zigbee/Thread) + Modbus-TCP gateway map, the user/security + TLS settings, firmware rev, and the logs.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A	Confirm the **webpages** and **EcoStruxure Power Commission** require authentication and that the **default password is changed at first login**; no anonymous configuration path. **Test:** open the webUI / connect EPC without valid credentials -> denied. **Ext. tools:** Web browser (HTTPS); EcoStruxure Power Commission; ReadOnlyEnum.	Webpages and EPC require login; default password changed; no anonymous access.	Default password must be changed.
SR/CR 1.2	Device & software-process I&A	Review the **paired wireless sensor list** and **Modbus device list** and confirm they match the approved inventory; wireless devices join only via **secure pairing**; downstream/upstream Modbus is constrained. **Test (isolated):** attempt to join a rogue wireless device without pairing -> rejected; rogue Modbus client -> per-interface limits apply. **Ext. tools:** Webpages (device lists); IEEE 802.15.4 analyzer (authorized); Modbus client (isolated); Wireshark (SPAN/tap).	Only paired wireless devices and approved Modbus peers connect; rogues rejected.	Wireless pairing is the device-auth mechanism.
SR/CR 1.3	Account management	Review user accounts/roles (webUI › user management); remove/disable defaults; confirm password change/reset works and the certificate is managed. **Ext. tools:** Webpages (accounts); EPC; procedure review.	Named, least-priv accounts; defaults removed; authenticators managed.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.4	Identifier management	In the Panel Server web UI › **Settings › User Management**, confirm each user has a unique identifier; confirm a unique device identity (hostname / IP) and unique identifiers for each paired wireless device. **Ext. tools:** Web UI (user + wireless-device inventory).	Unique user, device, and wireless-node identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm authenticators (passwords, keys, certs) are managed, protected and rotated; defaults changed. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Authenticator management verified individually.	
SR/NDR 1.6	Wireless access management	The Panel Server has a wireless (EcoStruxure wireless sensor) interface: in **Settings › Wireless Devices** confirm only commissioned/paired nodes are allowed, pairing is closed after commissioning, and the wireless network key is set; unpair unknown nodes. **Ext. tools:** Web UI (wireless commissioning list); RF survey (unexpected nodes).	Only authorized wireless nodes paired; pairing closed; network key set.	Wireless gateway.
SR/CR 1.7	Strength of password auth	Confirm the password policy (length/complexity) on local accounts; if an upstream directory is used, policy is enforced there. **Ext. tools:** Webpages (policy); attempt weak password -> rejected.	Strong password policy enforced per SL-3.	
SR/CR 1.8	PKI certificates	In **Settings › Security › Certificates** replace the factory self-signed HTTPS certificate with a CA-signed certificate; confirm validity/expiry and CA chain. **Ext. tools:** Browser cert view; openssl x509.	CA-signed HTTPS certificate installed and valid.	
SR/CR 1.9	Strength of public key auth	Confirm the HTTPS/TLS configuration uses strong ciphers and keys (>=2048 RSA / ECC); no weak or expired certificate. **Ext. tools:** testssl.sh (:443); openssl.	Strong TLS crypto; weak/self-signed cert replaced.	
SR/CR 1.10	Authenticator feedback	Confirm the web UI masks password entry (no cleartext echo) at login and in user management. **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm account-lockout behavior after repeated failed logins (firmware-dependent). **Test:** exceed the threshold and confirm lockout or record the gap + compensating control. **Ext. tools:** Repeated invalid logins (authorized); event-log review.	Lockout on excess failures, or Partial + compensating (WAF/segmentation).	Verify support in the deployed firmware.
SR/CR 1.12	System use notification	Set an approved login/use notice where the web UI supports a custom banner/message; otherwise enforce the notice at the access workstation as a compensating control. **Ext. tools:** Web UI (login message); visual.	Approved use notice presented (Partial/compensating if unsupported).	Compensating if unsupported.
SR/NDR 1.13	Access via untrusted networks	Segment the gateway; expose only HTTPS/MQTT-TLS off-segment; disable unused protocols and discovery; brokered remote access. **Ext. tools:** Nmap from each segment; firewall-rule review.	Only secure channels reachable off-segment; unauthenticated protocols contained.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm role-based access (e.g., Administrator vs viewer) follows least privilege for configuration, firmware, and security actions. **Test:** a viewer cannot change configuration/firmware. **Ext. tools:** Webpages (role review); attempt privileged action as viewer.	Least privilege enforced by role; privileged actions denied to non-admins.	
SR/CR 2.2	Wireless use control	Confirm the wireless interface enforces use control — only authorized/commissioned nodes communicate, the network is encrypted, and pairing requires operator action; disable wireless if unused. **Ext. tools:** Web UI (wireless settings); RF survey.	Wireless use restricted to authorized nodes; encrypted; pairing controlled.	Wireless gateway.
SR 2.3	Use Control for Portable and Mobile Devices	**N/A.** Device does not host portable/mobile-media use; USB/portable-device use is controlled at the engineering host (EWS).	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/NDR 2.4	Mobile code	No general-purpose mobile code runs on the gateway; confirm only signed firmware and the vendor web application execute; no untrusted scripts/apps are loadable. **Ext. tools:** Web UI (firmware/app review).	Only trusted signed code runs; no untrusted mobile code.	EDR/NDR-specific.
SR/CR 2.5	Session lock	Confirm the webUI inactivity timeout re-prompts for sign-in. **Ext. tools:** Manual idle test.	Idle webUI sessions time out.	
SR/CR 2.6	Remote session termination	Confirm web sessions can be terminated (logout) and that the **session inactivity timeout** closes idle sessions; failed-logon lockout applies. **Ext. tools:** Web UI (timeout/lockout test); browser.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent management sessions are limited or monitored; the gateway bounds simultaneous web/API and gateway connections. **Ext. tools:** Web UI (active sessions); Wireshark.	Concurrent sessions limited or monitored.	
SR/CR 2.8	Auditable events	Review the gateway **event/audit log** for logins, config changes, and firmware actions with user attribution; enable **syslog** offload. **Test:** make a change -> logged event with user + time. **Ext. tools:** Webpages (event log); syslog listener.	Security events logged with user + timestamp; offloaded to syslog.	
SR/CR 2.9	Audit storage capacity	The gateway log is a finite/rolling store; enable **Syslog** forwarding to the SIEM for retention and confirm sizing/threshold. **Ext. tools:** Web UI (syslog config); SIEM retention.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/syslog collector alerts on forwarding failure; the gateway continues logging locally so events are not silently lost. **Ext. tools:** SIEM alerting configuration.	Audit-failure alerting defined; local logging continues.	
SR/CR 2.11	Timestamps	Confirm authenticated **NTP** time source and consistent log timestamps. **Ext. tools:** Wireshark (NTP); webpages time settings.	Accurate synced time; consistent timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
NDR 2.13	Physical diagnostic & test interfaces	Control the gateway physical ports (USB service port, Ethernet, serial); keep it in a locked panel and disable/seal the service port when not in use. **Ext. tools:** Physical inspection (port covers/seals).	Physical/diagnostic interfaces controlled and sealed.	EDR/NDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Enable **HTTPS/TLS** (force redirect) on the webUI and **MQTT over TLS (8883)**; wireless mesh traffic is encrypted; Modbus is unencrypted -> segment. Replace the **self-signed cert** with a CA-signed cert. **Ext. tools:** testssl.sh / sslscan (:443, :8883); Wireshark (confirm TLS; no cleartext creds); openssl (cert chain).	WebUI/MQTT TLS-protected; CA-signed cert installed; Modbus compensated by segmentation.	
SR/NDR 3.2	Protection from malicious code	Confirm firmware is **digitally signed** and sourced from se.com; protect the configuration backup and baseline; verify integrity on update. **Ext. tools:** Firmware signature verify during EPC/webUI update; se.com checksum.	Only signed firmware loads; config integrity protected.	
SR/CR 3.3	Security functionality verification	After any change, re-verify the Security settings (protocols disabled, HTTPS enforced, accounts, wireless) against the baseline and export/compare the configuration. **Ext. tools:** Web UI (config export/compare); Nmap (confirm disabled services off).	Security settings match the hardening baseline after change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.4	Software & information integrity	Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/NDR 3.2** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software & information integrity verified individually.	
SR/CR 3.5	Input validation	Confirm the gateway tolerates malformed Modbus / protocol frames without faulting or dropping telemetry. **ISOLATED only:** fuzz the protocol interfaces on a representative unit and watch gateway/telemetry health. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of gateway function on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm the gateway handles faults/errors gracefully (diagnostics, watchdog, no loss of gateway function or info leakage). **Ext. tools:** Web UI (diagnostics/event review).	Graceful fault handling; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	HTTPS/TLS protects management sessions against replay/hijack; confirm all management access uses TLS and old sessions cannot be replayed. **Ext. tools:** Wireshark (session inspection).	Management sessions integrity-protected on TLS.	
SR/CR 3.9	Protection of audit information	Protect the event log and Syslog transport, and restrict admin access so logs cannot be cleared/altered by unauthorized users. **Ext. tools:** Web UI (role review); SIEM access review.	Audit records protected from unauthorized read/modify/delete.	
NDR 3.10	Support for updates	Verify signed firmware upgrade via EPC / webUI with a rollback/recovery path. **Ext. tools:** EPC firmware update (authorized window).	Signed firmware update supported and verified.	EDR-specific.
NDR 3.11	Physical tamper resistance & detection	Confirm physical tamper resistance/detection (device requirement). **Steps:** for this product this is assessed with the same evidence as **NDR 3.10** above (shared steps); confirm this requirement individually and adjudicate it separately.	Physical tamper resistance & detection verified individually.	NDR-specific.
NDR 3.12	Provisioning product-supplier roots of trust	The gateway accepts only Schneider-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** Web UI / Power Commission (signature verify); se.com checksum.	Supplier signing root intact; unsigned firmware rejected.	EDR/NDR-specific.
NDR 3.13	Provisioning asset-owner roots of trust	Where HTTPS/802.1X uses asset-owner certificates, confirm the asset owner can provision/manage its own certificate (upload CA-signed cert in Security › Certificates); else record the compensating control. **Ext. tools:** Web UI (certificate upload/verify).	Asset-owner certificate provisioning supported/verified, or compensating control recorded.	EDR/NDR-specific.
NDR 3.14	Integrity of the boot process	Confirm the gateway validates signed-firmware integrity before execution; no unsigned/tampered firmware runs. Capture firmware version + signature status. **Ext. tools:** Web UI (firmware version/signature).	Firmware integrity validated before execution; only signed firmware boots.	EDR/NDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission or repurpose, reset the gateway to factory defaults to clear users, configuration, wireless pairings, and logs; confirm credentials/config are not recoverable. **Ext. tools:** Web UI (factory reset); verify config cleared.	Sensitive data purged on decommission or reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.3	Use of cryptography	Confirm TLS 1.2/1.3 with strong ciphers on HTTPS/MQTT; replace self-signed cert; disable weak protocol versions. **Ext. tools:** testssl.sh / sslyze (:443, :8883).	Modern TLS + strong ciphers; self-signed default replaced.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	As a gateway/NDR, confirm it separates the wireless-sensor / downstream Modbus network from the upstream supervisory network; only required flows cross; firewall at the boundary; Modbus-gateway mappings limited to approved registers/devices. **Ext. tools:** Nmap by zone (443/502/8883/161); firewall + Modbus-map review.	Downstream and upstream networks separated; only approved gateway flows permitted.	
SR/NDR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	NDR-specific.
SR/NDR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the event log is readable/exportable and **syslog** ships events to the SIEM; passive monitoring of the gateway segment. **Ext. tools:** Syslog listener (`nc -lu 514`); passive OT monitor.	Events accessible/exportable; forwarded to SIEM; monitoring active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Disable unused protocols to shrink the surface; rely on network rate-limiting; confirm the gateway keeps serving Modbus/telemetry under load. **ISOLATED:** flood test. **Ext. tools:** Traffic generator (ISOLATED); Wireshark.	Gateway keeps serving under load; surface minimized.	
SR/CR 7.2	Resource management	Confirm the gateway limits resource exhaustion — connection/rate limits and CPU headroom prevent a flood from denying gateway/telemetry service; monitor connection count and CPU. **Ext. tools:** Web UI (diagnostics); traffic generator (ISOLATED).	Resources bounded; gateway/telemetry continue under load.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.3	Control system backup	Capture a verified configuration backup via EPC; test restore on a spare gateway; re-pair wireless devices as needed. **Ext. tools:** `sha256sum` of config export; EPC restore (lab).	Recent verified config backup; restore tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Verify settings against the DOCA0211 baseline; **disable unused protocols/services** (Modbus if unused, SNMP, discovery/DPWS), change default ports, and disable plain HTTP. **Ext. tools:** Nmap (open protocols/ports); webUI settings review.	Only required protocols enabled; ports hardened; HTTP off; settings match baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Capture model/firmware and the connected wireless + Modbus device inventory from the webUI/EPC. **Ext. tools:** Webpages (device lists); ReadOnlyEnum.	Complete model/firmware + connected-device inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
EcoStruxure Power Commission (EPC) / webpages	Native config & device-list review (all)	Review users/roles, protocol enable/disable, certificate, wireless-pairing list, and Modbus map with a read-only account.	Read-only account; HTTPS only.
Config backup (export) + sha256sum	Baseline, drift, recovery (3.4, 7.3)	Export the configuration via EPC; hash it to detect drift; restore on a lab gateway.	Backup may hold secrets — protect it.
testssl.sh / sslscan / sslyze	TLS/cipher/cert strength (3.1, 4.3)	`testssl.sh https://<pas>:443` and MQTT `:8883`; confirm TLS only, strong ciphers, CA-signed cert.	Read-only/safe.
openssl	Certificate inspection (3.1, 4.3)	`openssl s_client -connect <pas>:443 | openssl x509 -noout -issuer -dates`; confirm chain/validity.	Read-only.
Nmap / PortQry	Protocol/port exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 443,502,8883,161,123 -T2 <pas>`; scan by zone; confirm unused protocols closed.	Tune timing on production.
Wireshark / tcpdump	Comm integrity & confidentiality (1.2, 3.1)	SPAN/tap; confirm 443/8883 TLS and no cleartext creds on Modbus 502; inspect wireless-mesh exposure.	Passive; SPAN/tap only.
IEEE 802.15.4 analyzer	Wireless pairing/security (1.2)	With authorization, observe the Zigbee/Thread mesh; confirm only paired devices join and traffic is encrypted.	Authorized; do not disrupt the mesh.
Modbus test client	Unauthenticated-protocol exposure (1.2, 5.2)	Read-only Modbus queries to confirm which registers/devices answer without auth; verify gateway map limits.	Read-only on production.
Syslog listener (nc / rsyslog)	Log offload verification (6.1, 6.2)	Stand up a listener; trigger a login/config event; confirm the gateway forwards it to the SIEM.	Coordinate with SIEM team.
ReadOnlyEnum	Host/network/protocol enumeration (7.8)	Enumerate exposed services/protocols read-only.	Read-only.

Tool / method	Verifies	How to use — steps / example	Constraints
Traffic generator	DoS resilience (7.1)	High-rate protocol testing while watching that Modbus/telemetry service continues.	ISOLATED/non-production; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.